

Clase 171 — Active Directory: Kerberoasting y ataques a Kerberos

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *The Hacker Recipes (Kerberos) / MITRE ATT&CK T1558*  Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Entender el protocolo Kerberos lo suficiente para atacar sus puntos débiles: Kerberoasting (robo y crackeo offline de tickets de servicio), AS-REP Roasting (usuarios sin preautenticación) y las bases de los ataques de tickets. El alumno ejecutará estos ataques en su AD lab y comprenderá por qué funcionan y cómo se detectan.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** el flujo Kerberos (AS-REQ/REP, TGS-REQ/REP) y dónde falla.
2. **Ejecutar** Kerberoasting y crackear el hash offline en el lab.
3. **Realizar** AS-REP Roasting contra cuentas sin preautenticación.
4. **Relacionar** cada ataque con su ID ATT&CK y su detección.
5. **Recomendar** mitigaciones (contraseñas fuertes de servicio, gMSA, monitoreo).

Temas

#	Tema	Por qué importa
1	Flujo Kerberos	Base para entender los ataques
2	TGT vs TGS	Distintos tickets, distintos abusos
3	Kerberoasting (T1558.003)	Crackeo offline de cuentas de servicio
4	AS-REP Roasting (T1558.004)	Sin preautenticación = hash gratis
5	Tipos de cifrado (RC4 vs AES)	RC4 facilita el crackeo
6	Crackeo offline	Hashcat sobre los tickets
7	Detección y mitigación	Cómo lo ve y frena el Blue Team

Definiciones y características

- **TGT (Ticket Granting Ticket):** ticket inicial que prueba la identidad. Característica: cifrado con la clave de `krbtgt`.
- **TGS (Ticket Granting Service ticket):** ticket para un servicio concreto. Característica: parte va cifrada con el hash de la cuenta de servicio → crackeable.

- **Kerberoasting:** pedir TGS de cuentas con SPN y crackear offline su contraseña. Característica: no requiere privilegios, solo una cuenta de dominio.
- **AS-REP Roasting:** para usuarios con "no preauth", el AS-REP contiene material crackeable. Característica: ni siquiera hace falta conocer una contraseña.
- **Preautenticación:** paso que evita ataques al AS-REQ. Característica: deshabilitarla abre AS-REP Roasting.
- **RC4 (etype 23):** cifrado débil aún soportado. Característica: acelera enormemente el crackeo frente a AES.

Herramientas y preparación

- El AD lab / GOAD de la clase anterior, con al menos una cuenta de servicio con SPN y contraseña débil.
- **Impacket:** `GetUserSPNs.py` , `GetNPUsers.py` .
- **Rubeus** (desde Windows) como alternativa nativa.
- **Hashcat** con diccionarios (rockyou) para el crackeo offline.

⚠ Ejecuta estos ataques solo en tu AD lab / GOAD. El crackeo offline no toca el DC más de lo normal, pero solicitar muchos TGS es telemetría; hazlo comprendiendo la detección. Nunca contra dominios ajenos sin autorización.

Laboratorio guiado

1. **Repaso del flujo.** Dibuja AS-REQ → AS-REP (TGT) → TGS-REQ → TGS-REP y marca dónde entra material crackeable.
2. **Kerberoasting con Impacket:**

```
bash GetUserSPNs.py lab.local/lowuser:Passw0rd -dc-ip 10.10.10.10 -request -outputfile roast.txt
```

3. **Crackea offline:**

```
bash hashcat -m 13100 roast.txt /usr/share/wordlists/rockyou.txt
```

Recupera la contraseña de la cuenta de servicio. 4. **AS-REP Roasting:**

```
bash GetNPUsers.py lab.local/ -usersfile users.txt -dc-ip 10.10.10.10 -no-pass -format hashcat hashcat -m 18200 asrep.txt rockyou.txt
```

5. **Con Rubeus (Windows):** `Rubeus.exe kerberoast /outfile:roast.txt` y compara el flujo con Impacket.
6. **Fuerza RC4 y compara.** Solicita el TGS con etype RC4 y observa cuánto más rápido crackear frente a AES.
7. **Detección.** Revisa en el DC los eventos `4769` (TGS solicitado) con etype 0x17 (RC4) y documenta cómo el Blue Team los usa para alertar.

Ejercicios

1. Describe el flujo Kerberos y explica por qué el TGS es crackeable.
2. Ejecuta Kerberoasting y crackea al menos una cuenta del lab.
3. Encuentra una cuenta sin preautenticación y haz AS-REP Roasting.
4. Compara tiempos de crackeo RC4 vs AES para el mismo hash.
5. Explica cómo gMSA mitiga el Kerberoasting.
6. Escribe la regla de detección basada en el evento 4769 con RC4.

Reto verificable

Compromete la contraseña de una **cuenta de servicio** de tu AD lab mediante Kerberoasting y crackeo offline, y documenta el evento que el DC generó. **Criterio de aceptación:** obtienes en claro la contraseña de una cuenta con SPN, muestras el comando de solicitud y el de crackeo, e identificas el evento `4769` con etype RC4 correspondiente en el registro del DC.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No devuelve hashes	No hay cuentas con SPN o credenciales inválidas; revisa enumeración (Clase 170)
Hashcat no cracker	Contraseña fuerte o modo incorrecto; verifica <code>-m 13100/18200</code> y el diccionario
AS-REP Roasting vacío	Ninguna cuenta con "no preauth"; configúrala en el lab para practicar
Solo hashes AES	Servicio con AES; el crackeo es más lento, usa mejor diccionario/reglas
Detectado al instante	Muchas solicitudes RC4; el SOC alerta por eventos 4769 anómalos

Preguntas frecuentes

? ¿Kerberoasting necesita privilegios? No. Cualquier cuenta de dominio puede solicitar TGS de servicios con SPN. Por eso es tan popular: bajo requisito, alto impacto si hay contraseñas débiles.

? ¿Por qué RC4 y no AES? RC4 se cracker mucho más rápido. Los atacantes fuerzan RC4 cuando pueden; deshabilitarlo y monitorizar el etype 0x17 es una buena defensa.

? ¿Cómo se previene? Contraseñas largas y aleatorias para cuentas de servicio, uso de gMSA/dMSA, deshabilitar RC4 y monitorizar solicitudes de TGS anómalas.

Referencias

- The Hacker Recipes — *Kerberoasting / AS-REP Roasting*.
<https://www.thehacker.recipes/ad/movement/kerberos>
- MITRE ATT&CK — *Steal or Forge Kerberos Tickets* (`T1558`).
<https://attack.mitre.org/techniques/T1558/>
- Rubeus. <https://github.com/GhostPack/Rubeus>
- Hashcat modes. https://hashcat.net/wiki/doku.php?id=example_hashes

Siguiente clase

Clase 172 - Active Directory: Pass-the-Hash y Pass-the-Ticket